MODULE 09 · DOMAIN 2 - ACCOUNT MANAGEMENT AND DATA GOVERNANCE

Authentication, network policies and encryption

Who you are, where you are connecting from, and whether the data is readable at all.

DOMAIN 2 of 5 WEIGHT 20% MODULE 9 of 31

admin@sthithapragna.com

How a user proves who they are

METHOD	NOTES
Password	Governed by password policies. No longer sufficient alone for human users.
Multi-factor	Duo, authenticator apps (TOTP), or passkeys. A second factor, never a replacement.
Federated / SSO	SAML 2.0 via an identity provider. Snowflake is the service provider.
OAuth	Snowflake OAuth, or External OAuth via your own authorisation server.
Key-pair	User holds the private key, Snowflake the public key. Standard for programmatic access.
Programmatic access token	Used in place of a password by tools that cannot do MFA.

ON THE EXAM

All Standard Edition. Authentication is never an edition question.

User types now matter

- **TYPE = PERSON.** A human being, signing in interactively. Subject to MFA enforcement.
- **TYPE = SERVICE.** A programmatic identity. **Exempt from MFA enforcement**, and cannot use a password.
- **TYPE = LEGACY_SERVICE.** A transitional type for service accounts still using passwords.
- Service users authenticate with **key-pair, OAuth, a programmatic access token, or workload identity federation**.
- Snowflake plans that no new LEGACY_SERVICE users can be created from mid-2026.

> ON THE EXAM
>
> This is the modern answer to 'how should an automated pipeline authenticate'. Older courses say key-pair and stop.

MFA is being enforced, not merely offered

- Snowflake is **blocking single-factor password sign-ins for human users**, rolled out through behaviour change bundles.
- **SSO and OAuth users are not affected.** The enforcement targets password sign-ins to Snowsight.
- Excluded from the rollout: **managed accounts, trial accounts and reader accounts**.
- MFA methods now include **authenticator apps** and **passkeys**, alongside Duo.
- **A passkey is a second factor**, not a replacement for the username and password.

> ON THE EXAM
>
> The exam still tests the classic list. Know that list, and know that 'password only' is no longer a viable answer for a human.

Authentication policies tie it together

- A schema-level object controlling **which authentication methods are permitted**, applied to an account or a user.
- Controls include **MFA_ENROLLMENT**, **CLIENT_TYPES**, **AUTHENTICATION_METHODS** and **PAT_POLICY**.
- By default, a user must be subject to a **network policy** before they can generate or use a **programmatic access token**.
- Password policies remain separate, governing length, complexity, age and retry limits.

> ON THE EXAM
>
> That PAT-and-network-policy dependency is a neat design: a token that works from anywhere is a password with extra steps.

Network rules and network policies

NETWORK RULE

A schema-level object

- Lives in a database and schema, like a table
- Holds identifiers in a VALUE_LIST
- MODE is INGRESS or EGRESS
- TYPE is IPV4, IPV6, AWSVPCEID, AZURELINKID, HOST_PORT

NETWORK POLICY

An account-level object

- Not contained in a database at all
- Holds rules in an allowed list and a blocked list
- Does nothing until activated on something
- Applied to an account, a security integration, or a user

THE TIEBREAKER

The object level is the distinction to memorise. Rules live in schemas; policies do not.

How the lists are evaluated

- **Precedence: user beats security integration beats account.** The most specific policy wins.
- **The blocked list is applied first.** An address in both lists is blocked.
- **Private connectivity rules take precedence** over IPv4 and IPv6 rules for a request arriving that way.
- **An empty network policy allows nothing.** Creating one with no allowed entries locks everybody out.
- To block all public access, put a rule containing **0.0.0.0/0 in the blocked list**, leaving only private connectivity.

> ON THE EXAM
>
> Always confirm your own access is allowed before applying a blocking policy. Locking out every administrator is a support ticket.

The encryption key hierarchy

01

Root key

Lives in a hardware security module and never leaves it.

02

Account master key

One per account. Wrapped by the root key.

03

Table master key

One per table. Wrapped by the account master key.

04

File key

Derived per file. Encrypts the actual micro-partition data.

ON THE EXAM

Each level narrows the scope. That containment is the stated purpose: one key protects less data, for less time.

Key rotation or rekeying?

KEY ROTATION

Automatic, every 30 days

- Account and table master keys over 30 days old
- Old key retired, new key created
- Retired keys used only for decryption
- Existing data is NOT re-encrypted

PERIODIC REKEYING

Optional, annual

- Data protected by retired keys IS re-encrypted
- New keys created; old ones destroyed
- Enterprise Edition or higher
- Must be enabled by an account administrator

THE TIEBREAKER

Rotation changes which key encrypts new data. Rekeying changes the key protecting data that already exists.

Tri-Secret Secure

- **Business Critical.** A Snowflake-maintained key combined with a **customer-managed key** in your cloud provider's KMS.
- Together they form a **composite master key**, which acts as the account master key and wraps the keys below it.
- The composite key **never encrypts raw data directly**. It wraps table master keys, which derive file keys.
- **If the customer-managed key is revoked, Snowflake can no longer decrypt the data.** That is the feature, and the risk.
- Only **one** CMK at a time. Deleting an older CMK version causes data loss.

> ON THE EXAM
>
> The genuine use case is a kill switch: revoke your key and the data becomes unreadable, including to Snowflake.

How this module gets tested

THE QUESTION SHAPE	WHAT IT IS REALLY ASKING
'How should this automated process authenticate?'	Key-pair, OAuth, PAT or WIF. Never a password.
'Only our office should reach the account'	Network rule plus network policy, activated.
'A user can connect despite the account policy'	Precedence. A user-level policy overrode it.
'We must re-encrypt existing data annually'	Periodic rekeying. Enterprise. Not rotation.
'We need to be able to make the data unreadable'	Tri-Secret Secure. Business Critical.
'Which key encrypts the micro-partition?'	The file key. Not the account or table master key.

ON THE EXAM

Six shapes cover this module. The middle two are where careless reading costs marks.

An orchestration tool runs unattended overnight and connects to Snowflake using a username and password. After a recent change, its connections have begun failing during the sign-in step, while the team's interactive Snowsight sessions are unaffected.

The team proposes storing an MFA push approval in the tool's configuration so it can complete the second factor automatically.

What is the correct approach?

A Store the MFA approval as proposed, which is the documented pattern for unattended tools.

B Create the identity as TYPE = SERVICE and authenticate with key-pair, OAuth, a PAT or workload identity federation.

C Move the tool to SSO, so that federated authentication bypasses the requirement.

D Grant the tool's user the ACCOUNTADMIN role, which is exempt from authentication policies.

◆ PAUSE AND DECIDE

What is the correct approach?

A. Store the MFA approval in config.

Not a documented pattern, and storing a second factor next to the first defeats the point of having two.

B. TYPE = SERVICE with key-pair, OAuth, PAT or WIF.

Service users are exempt from MFA enforcement and cannot use passwords. This is the documented answer for programmatic access.

C. Move the tool to SSO.

SSO users are genuinely exempt from the Snowsight enforcement. But SSO is an interactive browser flow, which an unattended job cannot complete.

D. Grant ACCOUNTADMIN for exemption.

Roles do not exempt anyone from authentication. It also violates the documented advice against ACCOUNTADMIN in automation.

THE SIGNAL

'Interactive sessions unaffected' is the clue: this is MFA enforcement on password sign-ins, and only human users are targeted.

> An account-level network policy allows only the corporate office range. A contractor working from home reports that they can still connect normally, which the security team did not expect.
>
> Investigation shows a second network policy exists, listing the contractor's home address in its allowed list, and it is applied to their user.

Why can the contractor connect, and what governs this?

A Both policies apply, and Snowflake takes the union of every allowed list in the account.

B The account policy is invalid because a second policy exists. Only one policy may be active per account.

C A user-level network policy overrides an account-level one. The most specific policy wins.

D Network policies only apply to interactive sign-ins, and the contractor is using a driver.

◆ PAUSE AND DECIDE

Why can the contractor connect, and what governs this?

A Snowflake takes the union of allowed lists.

There is no union. Precedence selects one policy, and the others do not contribute.

B Only one policy may be active per account.

Policies can be applied at three levels simultaneously. That is exactly why precedence rules exist.

C User-level overrides account-level.

Documented precedence: user beats security integration beats account. The account policy is not consulted for this user.

D Policies only apply to interactive sign-ins.

They apply to all connections. Different authentication methods do not escape network policy.

THE SIGNAL

The account policy is not weakened, it is simply not consulted for that user. Audit user-level policies, not just the account one.

> An internal audit requires that data at rest is re-encrypted with newly generated keys at least once a year. It also requires that keys older than one year are destroyed rather than merely retired.
>
> An architect states that Snowflake already rotates keys every 30 days, so the requirement is satisfied automatically. The account is on Enterprise Edition.

Is the architect correct, and what is required?

A. Correct. Rotation every 30 days re-encrypts all existing data, which exceeds the requirement.

B. Incorrect. Tri-Secret Secure must be enabled, which requires an upgrade to Business Critical.

C. Incorrect. Rekeying is not available in Snowflake, so the requirement must be waived.

D. Incorrect. Rotation does not re-encrypt existing data. Periodic rekeying must be enabled by an account administrator.

◆ PAUSE AND DECIDE

Is the architect correct, and what is required?

A Rotation re-encrypts everything.

The architect's belief, and the whole point of the question. Rotation retires a key and encrypts new data; existing files keep their old key.

B Tri-Secret Secure, needing Business Critical.

Tri-Secret Secure is about who controls the key, not about re-encrypting data. The audit said nothing about customer-managed keys.

C Rekeying is not available.

It is. Periodic rekeying is a documented Enterprise feature, and the account is already on Enterprise.

D Rotation does not re-encrypt. Enable periodic rekeying.

Annual re-encryption of data under retired keys, with old keys destroyed. Enterprise, and enabled by an account administrator.

THE SIGNAL

Rotation and rekeying sound like the same word. Rotation changes the key for new data; rekeying changes it for old data.

> A defence contractor requires the ability to render all of its Snowflake data permanently unreadable within minutes. That includes unreadable to Snowflake itself, in the event of a confirmed compromise. No support ticket or vendor action may be needed.
>
> They currently run Enterprise Edition with periodic rekeying enabled.

What should they implement?

A. Tri-Secret Secure on Business Critical. Revoking the customer-managed key makes the data undecryptable.

B. A network policy blocking all public access, which prevents any further reads of the data.

C. Trigger an immediate rekeying operation, which destroys the previous keys and blocks access.

D. Set Time Travel to 0 and drop the databases, which sends the data straight into Fail-safe.

◆ PAUSE AND DECIDE

What should they implement?

A Tri-Secret Secure. Revoke the customer-managed key.

The composite master key needs both halves. Revoke your half and Snowflake cannot decrypt anything, with no vendor action needed.

B Block all public access.

Stops connections. The data remains perfectly readable to anyone who does get in, and to Snowflake.

C Trigger an immediate rekeying.

Rekeying re-encrypts data with new keys that Snowflake still holds. The data stays readable throughout, by design.

D Time Travel 0, then drop the databases.

Destroys the data rather than protecting it, and it sits in Fail-safe for 7 days where only Snowflake can reach it.

THE SIGNAL

'Including to Snowflake itself' and 'no vendor action' are the two phrases. Only a key you hold satisfies both.

What to carry into the next module

- **Service users are exempt from MFA and cannot use passwords.** Key-pair, OAuth, PAT or WIF.
- **Network rules are schema objects; network policies are account objects** and do nothing until activated.
- **User beats security integration beats account.** Blocked list is applied first.
- **Root, account master, table master, file.** The file key encrypts the data.
- **Rotation is automatic and does not re-encrypt. Rekeying is annual, optional, Enterprise.** Tri-Secret Secure is Business Critical.

> ON THE EXAM
>
> Next: masking, row access policies, tags, classification and lineage. The governance half of Domain 2.